FINGERPRINT // 5703239D8726B163

// CONFIDENTIAL STRATEGY //

OMNIPOTENCE ENGAGEMENT ARCHITECTURE

Strategic Nexus

Strategic Security Scoping v33.0 Omni-Review

ENTITY

Global Financial Bank

NEXUS SCORE

70%

70
NEXUS INDEX

1.1 Engagement Coverage Index

This score reflects the breadth of technical validation across core governance pillars.

PILLAR	STATUS	PRIORITY
GOV	VALIDATED	Strategic
RES	VALIDATED	Strategic
INT	VALIDATED	Strategic
PRI	GAP	Strategic
SOV	VALIDATED	Strategic
ID	GAP	Strategic

1.5 Regulatory Alignment: Global Regulated Enterprise (DORA, FRB, HKMA, PRA)

Narrative: A unified global compliance scoping document consolidating DORA, FRB, HKMA, and PRA requirements.

FRAMEWORK **DORA**

ICT Asset Criticality Mapping

Under DORA, scoping must start with the ICT Asset Register. Every asset in scope must be mapped to a 'Critical or Important Function' (CIF). If an asset supports a CIF, it is subject to more rigorous testing and reporting requirements.

Third-Party ICT Risk

DORA requires that testing includes third-party ICT service providers where they support critical or important functions. This scoping pack must include a list of involved third parties and confirmation of their authorization to test.

Threat Intelligence Requirements

For TLPT (Threat-Led Penetration Testing), the scope must be driven by current, relevant threat intelligence. The scenarios defined in this pack should match the TTPs of actors targeting the financial sector.

FRAMEWORK **FRB**

SR 13-1 / Vendor Risk

The scoping must encompass critical third-party vendors and external facing infrastructure in alignment with FRB supervision expectations.

FRAMEWORK **HKMA**

iCAST Execution

Simulations must cover the 'Assume Breach' methodology to assess the detection and response capabilities of the institution's Security Operations Center (SOC).

FRAMEWORK **PRA**

CBEST Intelligence-Led Testing

Testing must be driven by bespoke threat intelligence targeting the specific critical business services (CBS) of the UK financial institution.

FRAMEWORK MITRE

T1190 - Exploit Public-Facing Application

Adversaries may attempt to take advantage of a weakness in an Internet-facing computer or program using software, data, or commands in order to cause unintended or unanticipated behavior.

T1078 - Valid Accounts

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.

T1566 - Phishing

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering.

T1059 - Command and Scripting Interpreter

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries.

FRAMEWORK OWASP

A01:2021-Broken Access Control

Testing must validate that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification, or destruction of all data.

A02:2021-Cryptographic Failures

Testing must verify the protection of sensitive data in transit and at rest. This includes passwords, credit card numbers, health records, personal information, and business secrets.

A03:2021-Injection

Testing must validate that user-supplied data is not interpreted as commands or queries (e.g., SQL, NoSQL, OS command, ORM, LDAP, and EL expression or OGNL injection).

A04:2021-Insecure Design

Testing must evaluate the architectural design for missing or ineffective control design. Insecure design cannot be fixed by a perfect implementation.

FRAMEWORK CIS

Control 1: Inventory and Control of Enterprise Assets

Actively manage (inventory, track, and correct) all enterprise assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments.

Control 4: Secure Configuration of Enterprise Assets and Software

Establish and maintain the secure configuration of enterprise assets and software.

Control 12: Network Infrastructure Management

Establish, implement, and actively manage network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

Technical Data Governance

2.1 Digital Chain of Evidence

Artifacts produced during this engagement follow a cryptographically-verifiable lifecycle.

LIFECYCLE PHASE	VALIDATION METHOD
Acquisition	SHA-256 Verified Capture
Processing	Air-Gapped Analysis Environment
Destruction	NIST 800-88 Compliant Wipe

Technical Scope of Work

PT-NET-EXT — External Network Penetration Test

A structured assessment of internet-facing infrastructure including firewalls, VPNs, mail gateways, and publicly reachable hosts. Testers simulate real-world attackers attempting to gain unauthorised access from outside the perimeter. Findings are rated by exploitability and business impact.

2 Days | €3,500 Budgetary ALLOC

PT-APP-WEB — Web Application Penetration Test

Manual-led security testing of web applications aligned to the OWASP Top 10 and WSTG, covering injection flaws, broken authentication, sensitive data exposure, XML external entities, broken access control, security misconfigurations, XSS, insecure deserialisation, and business logic vulnerabilities.

3 Days | €4,000 Budgetary ALLOC

PT-APP-API — REST/GraphQL API Security Testing

Targeted assessment of REST, SOAP, and GraphQL APIs using the OWASP API Security Top 10 framework. Covers broken object-level authorisation, excessive data exposure, lack of rate limiting, broken function-level authorisation, mass assignment, security misconfiguration, and injection flaws.

2 Days | €3,500 Budgetary ALLOC

RT-FULL — Full Red Team Engagement

An adversary simulation engagement where a dedicated red team uses realistic threat actor TTPs to attack the organisation across all vectors — digital, physical, and human — without prior disclosure to defenders. Measures the organisation's detection, response, and containment capabilities.

17 Days | €25,000 Budgetary ALLOC

PT-CLD-INF — Cloud Infrastructure Penetration Test

Assessment of cloud-native infrastructure, IAM, and resource configurations.

3 Days | €5,000 Budgetary ALLOC

Omni Control Matrix

PART III.B: OMNI MATRIX

3.1 Omni Control Mapping

The following granular controls are in scope for the selected execution modules.

CONTROL ID	DOMAIN	DESCRIPTION
AC_01	None	None
IA_02	None	None
SI_04	None	None

RACI Governance

PART III.C: RACI MATRIX

3.2 RACI Governance Matrix

Responsibility Assignment Matrix for engagement activities.

ACTIVITY	PROVIDER	CLIENT SEC LEAD	CLIENT IT	CLIENT EXEC
Project Kick-off	R	A	C	I
Access Provisioning	C	I	R	A
Technical Testing	R	A	I	C
Report Delivery	R	A	C	I
Remediation Sign-off	C	I	R	A

Verification & Sign-off

PART IV: AUTHORIZATION

NEXUS SEAL

Executive Sponsor Approval

Lead Strategic Provider

FINGERPRINT // 5703239D8726B163488D3CCF96775B8C98B26DCB751B6A4377F09C9524130A14

Compliance Coverage Scope Template

Document Type: Compliance Scope Definition
Version: 1.0
Date: [DATE]
Classification: Confidential

1. Organization Overview

PART V: REGULATORY EXECUTION

FIELD	DETAILS
Organization Name	
Industry	Financial Services / Banking
Annual Revenue	
Number of Employees	
Primary Locations	
Data Centers/Cloud Regions	

2. Applicable Compliance Frameworks

PART V: REGULATORY EXECUTION

2.1 Regulatory Compliance Requirements

FRAMEWORK	APPLICABLE	VERSION	ASSESSMENT DATE	NEXT DUE DATE
☐ DORA	☐ Yes ☐ No			
☐ FRB Supervision	☐ Yes ☐ No			
☐ HKMA iCAST	☐ Yes ☐ No			
☐ PRA CBEST	☐ Yes ☐ No			

2.2 Supervisory/Regulatory Authorities

AUTHORITY	JURISDICTION	REPORTING FREQUENCY	LAST ENGAGEMENT	NEXT DUE

3. Data Classification Summary

CLASSIFICATION	DESCRIPTION	SYSTEMS	VOLUME (EST.)	COMPLIANCE IMPACT
Trading Data	Market execution, order books			FRB, PRA, HKMA
Customer Financial	Account balances, transactions			DORA, FRB
SWIFT Messages	Cross-border transaction records			Systemic Risk
Confidential	Business sensitive strategy			Internal policy
Public	Publicly available data			Minimal

4. System Inventory by Compliance Domain

4.1 DORA Scope (EU Financial)

FUNCTION CATEGORY	CLASSIFICATION	ICT SYSTEMS	OUTSOURCED?
Critical Functions	☐ Critical ☐ Important		☐ Yes ☐ No
Financial Services			☐ Yes ☐ No
Payment Services			☐ Yes ☐ No

Supervisory Authority:

Last TLPT: ☐ Yes ☐ No ☐ Scheduled:

4.2 FRB Supervision Scope (US)

COMPONENT TYPE	SYSTEM NAME	CRITICALITY	SERVICE MODEL
Core Banking			☐ On-Prem ☐ Cloud
Payment Gateways			
Third-Party Risk			

Current Assessment Status: ☐ Satisfactory ☐ Needs Improvement ☐ Planning

4.3 HKMA iCAST Scope (Hong Kong)

DOMAIN	IN SCOPE	PRIMARY SYSTEMS	DEPENDENCY
CFI Requirements	☐ Yes ☐ No		
Critical Internet Facing	☐ Yes ☐ No		
Core Financial Systems	☐ Yes ☐ No		

Intelligence-Led Phase Complete: ☐ Yes ☐ No

4.4 PRA CBEST Scope (UK)

THREAT SCENARIO	PRIMARY TARGET	CRITICAL BUSINESS SERVICE	WHITE CELL CONTACT

5. Network Architecture Overview

PART V: REGULATORY EXECUTION

5.1 Network Zones and Segmentation

ZONE	PURPOSE	IP RANGE	CONTROLS	COMPLIANCE BOUNDARY
Core Banking	Ledger and balances		Firewall, MFA, VLAN	FRB / PRA
Trading DMZ	Low latency execution		WAF, IDS/IPS	HKMA / FRB
Payment Gateways	SWIFT/SEPA integration		Network isolation	DORA / Systemic
Internal Corp	General business		Standard controls	All
Cloud VPC	Cloud workloads		Security groups	Framework-specific

5.2 Third-Party ICT Provider Connections

PROVIDER	SERVICE TYPE	DATA SHARED	COMPLIANCE COVERAGE	CONTRACT REVIEW
				☐ Yes ☐ No
				☐ Yes ☐ No

6. Testing Requirements by Framework

6.1 Summary Matrix

FRAMEWORK	EXTERNAL TEST	INTERNAL TEST	APP TEST	CLOUD TEST	SEGMENTATION TEST	SOCIAL ENG	THREAT-LED / RT
DORA	✓	✓	✓	✓	✓	✓	TLPT
FRB	✓	✓	✓	✓	✓	Optional	Expected
HKMA	✓	✓	✓	✓	-	Optional	iCAST
PRA	✓	✓	✓	✓	✓	Optional	CBEST

6.2 Frequency Requirements

FRAMEWORK	MINIMUM FREQUENCY	ADDITIONAL TRIGGERS
DORA Basic	Annual	-
DORA TLPT	Every 3 years	Competent authority may adjust
FRB Supervision	Annual	Significant changes
HKMA iCAST	Defined by CFI tier	Significant changes
PRA CBEST	Every 2-3 years	Competent authority guidance

7. Tester Qualification Requirements

PART V: REGULATORY EXECUTION

FRAMEWORK	INDEPENDENCE REQUIRED	CERTIFICATION REQUIRED	SPECIFIC CERTIFICATION
DORA TLPT	Required (external)	Required	Qualified tester standards
FRB	Required	Recommended	Threat-Intel/Red Team verified
HKMA iCAST	Required	Required	CREST / Relevant provider
PRA CBEST	Required	Required	CREST / CSCS

8. Deliverables Mapping

8.1 Required Deliverables by Framework

DELIVERABLE	DORA	FRB	HKMA	PRA
Executive Summary	✓	✓	✓	✓
Technical Report	✓	✓	✓	✓
Finding Details with CVSS	✓	✓	✓	✓
Threat Intelligence Report	TLPT	Optional	iCAST	CBEST
Finding-to-Control Mapping	✓	✓	✓	✓
Retest Evidence	✓	✓	✓	✓

9. Risk Prioritization

9.1 Severity Classification

RATING	CVSS RANGE	DEFINITION	GENERIC SLA
Critical	9.0-10.0	Exploitable, wide impact	Immediate
High	7.0-8.9	Exploitable, significant impact	7 days
Medium	4.0-6.9	Potentially exploitable	30 days
Low	0.1-3.9	Difficult to exploit	90 days
Informational	N/A	Observation	None

9.2 Framework-Specific Adjustments

FRAMEWORK	CRITICAL DEFINITION	HIGH DEFINITION
DORA	Threat to critical functions	Significant security weakness
FRB	Systemic risk to core banking	Major risk to availability/integrity
HKMA	Compromise of critical systems	Substantial access breach
PRA	Successful CBEST scenario	High impact on CBS

10. Sign-Off

Client Certification

I certify that the compliance scope described in this document is accurate and complete.

Name: _____

Title: _____

Signature: _____

Date: _____

Testing Provider Acceptance

Name: _____

Title: _____

Signature: _____

Date: _____

Document History

PART V: REGULATORY EXECUTION

VERSION	DATE	AUTHOR	CHANGES
1.0	[Date]	[Author]	Initial version

Penetration Testing Scope Statement Template

Document Type: Scope Definition
Version: 2.0
Date: [DATE]
Classification: Confidential
Industry: [Investment Management / Financial Services / Government Contracting]

---

1. Executive Information

FIELD	DETAILS
Project Name	[Project/Engagement Name]
Client Organization	[Company Name]
Client Contact	[Name, Title, Email, Phone]
Testing Provider	[Company Name]
Tester Lead	[Name, Email, Phone]
Engagement Manager	[Name, Email, Phone]
Scope Effective Date	[Start Date]
Scope Expiration Date	[End Date]
Assessment Tier	[Tier 1 (Critical) / Tier 2 (High) / Tier 3 (Medium) / Tier 4 (Low)]

2. Business Context

2.1 Purpose of Assessment

``` [Describe why this penetration test is being conducted]

Example: Annual security assessment required for DORA TLPT compliance and SOC 2 Type II certification. The assessment will evaluate the security posture of customer-facing applications, core banking systems, and internal network infrastructure to identify vulnerabilities before they can be exploited by threat actors. ```

## 2.2 Applicable Regulations

| REGULATION | JURISDICTION | TESTING REQUIREMENT |
|---|---|---|
| [DORA] | [EU] | [Threat-Led PT / Annual PT] |
| [PCI DSS] | [Global] | [Annual / After Changes] |
| [SWIFT CSP] | [Global] | [Annual] |
| [MAS TRM] | [Singapore] | [Annual] |
| [SEC/FINRA] | [US] | [Annual (Recommended)] |
| [SAMA] | [Saudi Arabia] | [Annual] |
| [Other] | [Other] | [Other] |

## 2.3 Business Objectives

- [ ] Identify critical vulnerabilities before exploitation
- [ ] Meet compliance requirements ([DORA / PCI DSS / SWIFT CSP / MAS / Other])
- [ ] Validate effectiveness of existing security controls
- [ ] Assess readiness for new system deployment
- [ ] Support security awareness program
- [ ] Other: ___

## 2.4 Success Criteria

``` [Define what constitutes a successful assessment]

Example: - All critical and high-severity vulnerabilities identified and documented - Testing completed within agreed timeline - Comprehensive report delivered within 2 weeks of testing completion - Client able to use findings to remediate vulnerabilities within SLA - Regulatory compliance evidence documented ```

---

3. Technical Scope

3.1 In-Scope Assets - Core Banking & Financial Systems

Core Banking Systems

ASSET ID	NAME/DESCRIPTION	TYPE	OWNER	DATA SENSITIVITY
CORE-001	[Core Banking Platform]	[Temenos/FLEXCUBE/Other]	[Owner]	[Critical - Financial Data]
CORE-002	[Payment Processing]	[Type]	[Owner]	[Critical - Transaction Data]

Trading & Treasury Systems

ASSET ID	NAME/DESCRIPTION	TYPE	OWNER	DATA SENSITIVITY
TRAD-001	[Trading Platform]	[Type]	[Owner]	[Critical - Market Data]
TRAD-002	[Treasury System]	[Type]	[Owner]	[Critical - Financial Data]

3.2 In-Scope Assets - Digital Channels

Internet & Mobile Banking

ASSET ID	NAME/DESCRIPTION	PLATFORM	URL/ENDPOINT	OWNER
DIG-001	[Internet Banking]	Web	[URL]	[Owner]
DIG-002	[Mobile Banking - iOS]	iOS	[Bundle ID]	[Owner]
DIG-003	[Mobile Banking - Android]	Android	[Package]	[Owner]

ATM/POS Network

ASSET ID	NAME/DESCRIPTION	TYPE	OWNER
ATM-001	[ATM Network]	ATM	[Owner]
POS-001	[POS Network]	POS	[Owner]

3.3 In-Scope Assets - Network Infrastructure

External Assets (Internet-Facing)

ASSET ID	NAME/DESCRIPTION	IP ADDRESS/URL	OWNER	DATA SENSITIVITY
EXT-001	[Name]	[IP/URL]	[Owner]	[Public/Internal/Confidential]
EXT-002	[Name]	[IP/URL]	[Owner]	[Public/Internal/Confidential]
EXT-003	[Name]	[IP/URL]	[Owner]	[Public/Internal/Confidential]

Total External IPs/URLs: ___

Internal Assets

ASSET ID	NAME/DESCRIPTION	NETWORK SEGMENT	OWNER	DATA SENSITIVITY
INT-001	[Name]	[VLAN/Subnet]	[Owner]	[Public/Internal/Confidential]
INT-002	[Name]	[VLAN/Subnet]	[Owner]	[Public/Internal/Confidential]

Total Internal Hosts: ___

3.4 In-Scope Assets - Applications

APP ID	APPLICATION NAME	TYPE	URL/ENDPOINT	AUTHENTICATION	OWNER
APP-001	[Name]	Web/Mobile/API	[URL]	[Method]	[Owner]
APP-002	[Name]	Web/Mobile/API	[URL]	[Method]	[Owner]

Total Applications: ___

3.5 In-Scope Assets - Cloud Infrastructure

CLOUD ID	PROVIDER	SERVICES	ACCOUNT/PROJECT	OWNER
CLD-001	AWS/Azure/GCP	[Services]	[Account]	[Owner]
CLD-002	AWS/Azure/GCP	[Services]	[Account]	[Owner]

3.6 In-Scope Assets - Payment Systems

PAYMENT ID	SYSTEM NAME	TYPE	OWNER	REGULATORY REQUIREMENT
PMT-001	[SWIFT Alliance]	SWIFT	[Owner]	[SWIFT CSP]
PMT-003	[ACH/Payment]	ACH	[Owner]	[NACHA/Regulatory]

3.7 Out-of-Scope Assets

The following are explicitly **excluded** from this assessment:

- [ ] Production database servers (write access limited)
- [ ] Mobile applications (separate engagement)
- [ ] Third-party vendor systems not owned by client
- [ ] Physical security systems (unless specifically requested)
- [ ] Social engineering (unless specifically requested)
- [ ] Third-party SaaS applications (except: _____)
- [ ] Legacy systems (end-of-life, documented risk)
- [ ] Physical security assessments
- [ ] Social engineering assessments
- [ ] Denial of Service testing
- [ ] Supply chain assessments
- [ ] [Other exclusions]

Reason for Exclusions: [Explain why certain assets are out of scope and any compensating controls]

3.3 Network Diagrams

Attached: ☐ Yes ☐ No

Location: [Reference to attached diagrams or Confluence URL]

4. Testing Types

PART VI: SCOPE DEFINITION

4.1 Required Testing Types

TEST TYPE	INCLUDED	NOTES
External Network Assessment	☐	[Any limitations]
Internal Network Assessment	☐	[VLANs excluded]
Web Application Testing	☐	[OWASP Top 10 + business logic]
API Security Testing	☐	[REST/GraphQL/SOAP]
Mobile Application Testing	☐	[iOS/Android/Backend]
Cloud Security Assessment	☐	[AWS/Azure/GCP]
Wireless Network Assessment	☐	[Specific SSIDs]
Social Engineering	☐	[Phishing/Physical]
Red Team / Full Attack Simulation	☐	[Objectives]

4.2 Testing Methodology

The following methodologies will be followed:

- [ ] NIST SP 800-115 (Technical Guide to Security Testing)
- [ ] OWASP Testing Guide v4.2
- [ ] OWASP ASVS
- [ ] PTES (Penetration Testing Execution Standard)
- [ ] CIS Controls Benchmark
- [ ] Cloud-specific ([CIS Benchmark / Vendor Best Practices])
- [ ] Custom methodology (describe below)

[If custom methodology, describe approach]

5. Compliance Requirements

5.1 Applicable Frameworks

FRAMEWORK	REQUIREMENT	TESTING SCOPE
☐ ISO 27001	A.12.6.1	[Vulnerability management]
☐ GDPR	Article 32	[Technical measures]
☐ SOX	IT General Controls	[Segregation of duties]
☐ NIST CSF	PR.AC	[Access controls]
☐ Industry-Specific	[Name]	[Requirements]

5.2 Compliance Deliverables

- [ ] Compliance-specific findings mapping
- [ ] Remediation guidance for compliance gaps
- [ ] Attestation letter for auditors
- [ ] Executive summary for board
- [ ] Raw scan data for auditor review

6. Constraints and Restrictions

6.1 Time Constraints

DAY	TIME WINDOW	NOTES
Monday	[Allowed/Hours]	[Notes]
Tuesday-Thursday	[Allowed/Hours]	[Notes]
Friday	[Allowed/Hours]	[Notes]
Weekend	[Allowed/Hours]	[Notes]

Testing Window: [Start Date] to [End Date]

6.2 Technical Restrictions

RESTRICTION	AFFECTED SYSTEMS	MITIGATION
No DoS testing	[Systems]	Excluded from scope
No credential brute force	[Systems]	Limited to 5 attempts
No database deletion	[Systems]	Read-only access only
No malware deployment	[Systems]	[Alternative approach]
Source IP restriction	[All/Specific]	[Whitelisted IPs below]

Whitelisted Tester IPs: `[IP 1] [IP 2]`

6.3 Data Handling

- [ ] No data exfiltration allowed
- [ ] Evidence limited to screenshots/evidence files
- [ ] PII handling required (PII Processing Agreement attached)
- [ ] Data retention: 90 days post engagement

---

7. Authorization and Approval

7.1 Authorization Matrix

ROLE	NAME	TITLE	SIGNATURE	DATE
System Owner				
Network Owner				
Security Lead				
Legal Counsel				
Executive Sponsor				

7.2 Supporting Documents Attached

- [ ] Network diagrams
- [ ] Asset inventory
- [ ] Authorization letters
- [ ] PII Processing Agreement
- [ ] Data Classification Guide
- [ ] Previous penetration test reports
- [ ] Security policies

8. Sign-Off

By signing below, the parties confirm that:

1. The assets and scope listed above are accurate and authorized for testing
2. All necessary approvals have been obtained
3. Rules of Engagement have been reviewed and accepted
4. Emergency contacts have been established

Client Authorization

Name: _____

Title: _____

Signature: _____

Date: _____

Testing Provider Acceptance

Name: _____

Title: _____

Signature: _____

Date: _____

Document Version History

VERSION	DATE	AUTHOR	CHANGES
1.0	[Date]	[Author]	Initial version

Asset Inventory Template

Project: [Project Name]
Date: [Date]
Owner: [Name]
Classification: Confidential

---

1. Asset Registry

1.1 External Assets (Internet-Facing)

ASSET ID	NAME	TYPE	IP ADDRESS	URL/DOMAIN	OWNER	DATA SENSITIVITY	TIER	LAST SECURITY REVIEW
EXT-001								
EXT-002								
EXT-003								
EXT-004								
EXT-005								

Asset Type Legend: Web Server | DNS | Email | VPN | CDN | Cloud LB | API | Trade Gateway | Open Banking API **Data Sensitivity Legend**: Public | Internal | Confidential | Restricted | Critical Financial **Tier Legend**: 1 = Critical (CBS) | 2 = Important | 3 = Standard

1.2 Internal Network Assets

ASSET ID	NAME	TYPE	IP ADDRESS	MAC ADDRESS	VLAN/SUBNET	OWNER	DATA SENSITIVITY	TIER
INT-001								
INT-002								
INT-003								
INT-004								
INT-005								

Asset Type Legend: Server | Workstation | Network Device | Database | Mainframe | Payment Gateway | Core Banking

1.3 Application Assets

APP ID	NAME	TYPE	URL/ENDPOINT	PLATFORM	AUTH METHOD	USERS	DATA SENSITIVITY	OWNER	TIER
APP-001									
APP-002									
APP-003									
APP-004									
APP-005									

Application Type: Web | Mobile | API | Desktop | Embedded | SaaS (Third-Party ICT) **Authentication Method**: None | Basic Auth | Form-based | OAuth 2.0 | SAML | LDAP | API Key | JWT | Multi-factor

1.4 Cloud Infrastructure

CLOUD ID	PROVIDER	ACCOUNT/PROJECT	REGION	SERVICES	OWNER	TIER
CLD-001	AWS/Azure/GCP					
CLD-002	AWS/Azure/GCP					
CLD-003	AWS/Azure/GCP					

Services: Compute | Storage | Database | Networking | Security | Analytics | Mainframe as a Service

1.5 Mobile Applications

MOBILE ID	APP NAME	PLATFORM	VERSION	BACKEND URL	OWNER	APP STORE	TIER
MOB-001		iOS/Android				Yes/No	
MOB-002		iOS/Android				Yes/No	

---

2. Network Architecture

PART VII: ASSET INVENTORY

2.1 Network Zones

ZONE	DESCRIPTION	IP RANGE	SECURITY LEVEL	CONNECTED ZONES
DMZ	External facing web and API		High	Internal, Internet
Core Banking	Ledger, balances, core apps		Critical	Internal
Trading DMZ	Low latency execution / fix		Critical	External exchanges
Payment Network	SWIFT, SEPA		Critical	Core Banking
Internal	Corporate workstations		Medium	DMZ, Data Center

2.2 Network Diagram Reference

Attached: ☐ Yes ☐ No

Location: [Reference link or file path]

---

3. Third-Party Connections (ICT Providers)

THIRD PARTY	SYSTEM	CONNECTION TYPE	DATA SHARED	RISK LEVEL	CONTRACT REVIEW
		VPN/Direct/API		Low/Med/High	☐ Yes ☐ No
		VPN/Direct/API		Low/Med/High	☐ Yes ☐ No
		VPN/Direct/API		Low/Med/High	☐ Yes ☐ No

4. Data Classification Summary

PART VII: ASSET INVENTORY

CLASSIFICATION	EXAMPLES	SYSTEMS	RISK LEVEL
Restricted	SWIFT messaging, PANs, Trade Secrets, Auth Tokens		Highest
Confidential	Customer Financial Data, Market Orders, PII		High
Internal	Corporate policies, internal ops		Medium
Public	Marketing materials, public disclosures		Low

5. Compliance Scope Mapping

PART VII: ASSET INVENTORY

COMPLIANCE FRAMEWORK	DATA TYPES / FOCUS	SYSTEMS IN SCOPE	TESTING FREQUENCY REQUIRED
DORA	Critical financial & payment services		Annual (TLPT 3 yrs)
FRB Supervision	Core banking and systemic risk		Annual
HKMA iCAST	CFI designated critical systems		Simulation based
PRA CBEST	Critical business services (CBS)		2-3 years

6. Asset Criticality Assessment

6.1 Business Impact Factors

FACTOR	WEIGHT	ASSESSMENT
Systemic Financial Impact	25%	$___ per hour transaction loss
Customer Financial Impact	20%	___ retail/commercial customers
Reputational Impact	20%	High/Medium/Low
Regulatory Impact	15%	Potential license revocation
Operational Impact	10%	Recovery time
Data Sensitivity	10%	Classification

6.2 Asset Criticality Matrix

```
Low Impact Medium Impact High Impact ┌──────────────┬──────────────┬──────────────┐ High Likelihood │ HIGH │
CRITICAL │ CRITICAL │ ├──────────────┼──────────────┼──────────────┤ Medium Likelihood │ MEDIUM │ HIGH │ CRITICAL │
├──────────────┼──────────────┼──────────────┤ Low Likelihood │ LOW │ MEDIUM │ HIGH │
└──────────────┴──────────────┴──────────────┘
```

Document Maintenance

VERSION	DATE	AUTHOR	CHANGES
1.0	[Date]	[Author]	Initial asset inventory

Next Review Date: [Date]

Rules of Engagement Template

Document Type: Rules of Engagement
Version: 1.0
Date: [DATE]
Related Scope: [Reference to Scope Statement]
Classification: Confidential

---

1. Introduction

1.1 Purpose

This document establishes the rules, procedures, and constraints for conducting authorized penetration testing activities. All parties must adhere to these rules to ensure: - Legal compliance - Business continuity - Data protection - Safe testing practices

1.2 Scope of This Document

These rules govern: - Permitted testing techniques - Prohibited activities - Communication procedures - Emergency protocols - Data handling requirements - Evidence preservation

2. Authorization

2.1 Legal Authorization

```
AUTHORIZED BY: [Client Organization Name]
AUTHORIZATION DATE: [Date]
SCOPE REFERENCE: [Linked Scope Statement ID]

This penetration testing engagement is conducted with explicit written authorization from the system owners. All testing activities are performed against systems for which the client has legal authority to permit security testing.
```

2.2 Authorization Boundaries

- Testing is **limited to assets** listed in the Scope Statement
- Testing is **valid only during** the agreed testing window
- Testing must **adhere to** all constraints listed in Section 4

---

3. Communication Procedures

3.1 Primary Contacts

ROLE	NAME	EMAIL	PHONE	SLACK/TEAMS
Client Project Lead	[Name]	[Email]	[Phone]	[Handle]
Client Security Lead	[Name]	[Email]	[Phone]	[Handle]
Test Team Lead	[Name]	[Email]	[Phone]	[Handle]
Test Engineer	[Name]	[Email]	[Phone]	[Handle]

3.2 Escalation Contacts (24/7)

ROLE	NAME	EMAIL	PHONE
Emergency - Client	[Name]	[Email]	[Phone]
Emergency - Test Team	[Name]	[Email]	[Phone]

3.3 Communication Schedule

MEETING/FREQUENCY	PURPOSE	ATTENDEES	FORMAT
Kickoff Call	Scope review, procedures	All contacts	Video call
Daily Standup (optional)	Status update	Leads	Slack/Teams
Weekly Report	Findings summary	Project leads	Email + Call
Critical Finding Alert	Immediate notification	Security lead	Phone + Email
Exit Interview	Preliminary findings	All contacts	Video call
Final Debrief	Report walkthrough	Stakeholders	In-person/Video

3.4 Communication Channels

CHANNEL	USE CASE	RESPONSE TIME
Email	Formal communications, reports	Within 4 business hours
Slack/Teams	Quick questions, status	Within 2 hours during testing
Phone	Critical issues, emergencies	Immediate
Encrypted Email	Sensitive findings	Within 4 business hours

4. Testing Constraints

4.1 Absolute Prohibitions

The following activities are **NEVER permitted** without explicit written approval:

PROHIBITED ACTIVITY	RATIONALE	EXCEPTION AVAILABLE?
Denial of Service (DoS) attacks	Business continuity	☐ Yes ☐ No
Data exfiltration	Data protection	☐ Yes ☐ No
Physical intrusion	Legal/safety	☐ Yes ☐ No
Social engineering (non-physical)	Human safety	☐ Yes ☐ No
Modifying system configurations	Availability	☐ Yes ☐ No
Deleting data or logs	Evidence integrity	☐ Yes ☐ No
Deploying malware/backdoors	Legal	☐ Yes ☐ No
Brute force attacks on auth systems	Account lockout	☐ Yes ☐ No
Testing production payment systems	Revenue impact	☐ Yes ☐ No

4.2 Testing Time Restrictions

DAY	ALLOWED HOURS	NOTES
Monday	TBD	
Tuesday	TBD	
Wednesday	TBD	
Thursday	TBD	
Friday	TBD	
Saturday	TBD	
Sunday	TBD	

Testing Window: [Start Date/Time] to [End Date/Time]

4.3 Rate Limiting

TEST TYPE	LIMITATION	NOTES
Port scans	Max [X] packets/second	Nmap rate limit
HTTP requests	Max [X] requests/second	Burp throttle
Authentication attempts	Max [X] per account	To prevent lockout
Credential stuffing	**NOT ALLOWED**	Prohibited activity

4.4 Source IP Whitelisting

All testing must originate from the following IP addresses:

```
PRIMARY TESTER IPs:
- TBD

FAILOVER IPs:
- TBD

If testing must originate from other IPs, pre-approval required.
```

---

5. Safety Protocols

PART VIII: RULES OF ENGAGEMENT

5.1 Kill Switch Criteria

Testing must be **immediately paused** if any of the following occur:

- [ ] System becomes unresponsive or crashes
- [ ] Business-critical service disruption detected
- [ ] Alert from security operations center
- [ ] Unexpected data access (beyond test scope)
- [ ] Any legal concern raised
- [ ] Client requests immediate halt
- [ ] Evidence of active compromise by third party

5.2 Kill Switch Procedure

```
STEP 1: Testing engineer identifies kill switch trigger
STEP 2: Immediately cease ALL active testing
STEP 3: Document:
- What triggered the stop
- Last command/action performed
- Systems affected
- Evidence collected
STEP 4: Contact Client Emergency Contact within 15 minutes
STEP 5: Await written authorization before resuming
STEP 6: Resume only after root cause addressed
```

5.3 System Impact Thresholds

IMPACT LEVEL	DEFINITION	REQUIRED ACTION
None	No observable impact	Continue testing
Minor	Brief slowdown, normal logs	Document, continue
Moderate	Service degradation	Pause, notify client
Severe	Service unavailable	STOP, emergency protocol
Critical	Data breach/financial impact	STOP, full incident response

6. Data Handling

6.1 Data Access Boundaries

DATA TYPE	ACCESS PERMITTED	NOTES
PII (Personally Identifiable Info)	☐ Yes ☐ No	[Restrictions]
Financial data	☐ Yes ☐ No	[Restrictions]
Healthcare data (PHI)	☐ Yes ☐ No	[Restrictions]
Authentication credentials	☐ Yes ☐ No	[Restrictions]
Business confidential	☐ Yes ☐ No	[Restrictions]

6.2 Evidence Handling

```
EVIDENCE COLLECTION RULES:

1. Only capture evidence necessary to demonstrate vulnerability
2. Screenshots preferred over raw data
3. No actual customer PII in screenshots
4. Hash and preserve original evidence
5. Encrypt all evidence at rest
6. Delete evidence within 90 days of engagement close
7. Evidence accessible only to named team members
```

6.3 Data Exfiltration Prevention

- [ ] Proof-of-concept only (no actual data theft)
- [ ] If sensitive data encountered, immediately document and stop
- [ ] Any exfiltrated data will be securely destroyed
- [ ] Client notified immediately if sensitive data accessed

---

7. Reporting Procedures

7.1 Finding Classification

SEVERITY	CVSS RANGE	DEFINITION	SLA
Critical	9.0-10.0	Immediate threat, active exploitation risk	24 hours
High	7.0-8.9	Significant vulnerability, likely exploitation	7 days
Medium	4.0-6.9	Moderate risk, some exploitation potential	30 days
Low	0.1-3.9	Limited risk, difficult exploitation	90 days
Informational	N/A	Best practice observation	None

7.2 Critical Finding Notification

``` CRITICAL FINDING PROCESS:

1. Tester identifies potential critical finding
2. Verify severity classification
3. Document preliminary evidence
4. Notify client security lead immediately
5. Phone call (required)
6. Follow-up email with details
7. Client confirms receipt and understanding
8. Provide detailed writeup within 24 hours
9. Coordinate remediation timing
10. Retest after remediation (if requested) ```

## 7.3 Report Delivery

| DELIVERABLE | AUDIENCE | FORMAT | TIMELINE |
|---|---|---|---|
| Executive Summary | C-Suite, Board | PDF, 2-3 pages | Final report |
| Technical Report | IT/Security Teams | PDF, full detail | Final report |
| Risk Matrix | Management | Excel/CSV | Weekly updates |
| Raw Findings | Security Team | JSON/XML/CSV | Final report |
| Remediation Tracker | IT Teams | Spreadsheet | With report |
```

8. Confidentiality

8.1 Non-Disclosure

All information gathered during this engagement is confidential: - Test results and findings - System architecture and configurations - Vulnerability details - Security weaknesses

8.2 Data Retention

DATA TYPE	RETENTION PERIOD	DESTRUCTION METHOD
Evidence files	90 days	Secure erase
Reports	1 year	Secure archive
Working documents	30 days	Secure delete
Communication records	1 year	Secure archive

8.3 Third-Party Disclosure

Findings may only be disclosed to: - Client organization and authorized personnel - Client's designated auditors (with written approval) - Legal authorities (if legally required)

---

9. Agreement and Signatures

9.1 Acceptance

By signing below, all parties agree to the rules and procedures outlined in this document.

Client Acceptance

Name: _____

Title: _____

Signature: _____

Date: _____

Testing Provider Acceptance

Name: _____

Title: _____

Signature: _____

Date: _____

Testing Engineer(s)

Name: _____

Signature: _____

Date: _____

Appendix A: Quick Reference Card

```
╔═══════════════════════════════════════════════════════════╗
╠═══════════════════════════════════════════════════════════╣
```

PENETRATION TEST QUICK REFERENCE

TESTING WINDOW: [Date Range]

WHITELISTED IPs: [IP List]

EMERGENCY CONTACT: [Name] - [Phone]

STOP IMMEDIATELY IF:
- System crashes or becomes unresponsive
- Service disruption detected
- SOC alerts on testing activity
- Unexpected sensitive data access
- Client requests halt

NEVER DO:
- DoS testing (unless explicitly authorized)
- Data exfiltration
- Modify configurations
- Delete data or logs
- Deploy malware or backdoors
- Physical intrusion

REPORT CRITICAL FINDINGS: Phone call + Email

SLA: 24 hours for critical finding notification

```
╚═══════════════════════════════════════════════════════════╝
```

Document Version History

VERSION	DATE	AUTHOR	CHANGES
1.0	[Date]	[Author]	Initial version

Penetration Test Finding Tracker

Project: [Project Name]
Engagement Period: [Start Date] - [End Date]
Report Date: [Date]
Classification: Confidential

---

1. Finding Summary

1.1 Statistics Overview

METRIC	COUNT
Critical Findings	0
High Findings	0
Medium Findings	0
Low Findings	0
Informational	0
Total Findings	0
Remediated	0
In Progress	0
Open	0

1.2 Risk Distribution

1.2 Risk Distribution

SEVERITY	COUNT	PERCENTAGE
Critical	0	0%
High	0	0%
Medium	0	0%
Low	0	0%
Info	0	0%

2. Findings Detail

Finding Template (Copy this block for each finding)

Finding ID: FIND-[###]
Title: [Vulnerability Title]
Severity: [Critical/High/Medium/Low/Informational]
CVSS Score: [X.X]
CVSS Vector: [Vector String]
Status: [Open/In Progress/Remediated/Verified]
Discovery Date: [Date]
Remediation Target: [Date]
Remediated Date: [Date]

Affected Asset(s): - [Asset ID] - [Asset Name]

Description: `[Detailed description of the vulnerability, how it was found, and why it's a risk]`

Evidence: `[Proof of concept steps, commands used, expected vs actual results]`

Impact: `[Business impact if exploited, what an attacker could achieve]`

Recommendations: `1. [Specific remediation step] 2. [Specific remediation step] 3. [Specific remediation step]`

Effort to Fix: [Low/Medium/High]

References: - [CVE if applicable] - [CWE] - [OWASP if applicable]

2.1 Critical Findings

FIND ID	TITLE	AFFECTED ASSET	CVSS	STATUS	OWNER	TARGET DATE
FIND-001						

2.2 High Findings

FIND ID	TITLE	AFFECTED ASSET	CVSS	STATUS	OWNER	TARGET DATE
FIND-002						
FIND-003						

2.3 Medium Findings

FIND ID	TITLE	AFFECTED ASSET	CVSS	STATUS	OWNER	TARGET DATE
FIND-004						
FIND-005						

2.4 Low Findings

FIND ID	TITLE	AFFECTED ASSET	CVSS	STATUS	OWNER	TARGET DATE
FIND-006						

2.5 Informational

FIND ID	TITLE	AFFECTED ASSET	STATUS	OWNER
FIND-007				

3. Remediation Tracking

PART IX: REMEDIATION TRACKER

3.1 By Status

STATUS	COUNT	PERCENTAGE
Open	0	0%
In Progress	0	0%
Remediated	0	0%
Verified	0	0%
Risk Accepted	0	0%

3.2 Remediation Timeline

WEEK	EXPECTED REMEDIATION %	ACTUAL REMEDIATION %
Week 1	10%	0%
Week 2	20%	0%
Week 3	40%	0%
Week 4	60%	0%
Week 6	80%	0%
Week 8	100%	0%

3.3 Open Findings by Owner

OWNER	CRITICAL	HIGH	MEDIUM	LOW	TOTAL
	0	0	0	0	0

4. Remediation Evidence

Finding: FIND-[###] - [Title]

STEP	ACTION	COMPLETED BY	DATE	EVIDENCE
1				
2				
3				

Retest Performed By: [Name]
Retest Date: [Date]

Retest Result: ☐ Verified Fixed ☐ Not Fixed ☐ Partially Fixed

Notes:

---

5. SLA Compliance

PART IX: REMEDIATION TRACKER

SEVERITY	FINDING COUNT	MET SLA	BREACHED SLA	COMPLIANCE RATE
Critical	0	0	0	N/A
High	0	0	0	N/A
Medium	0	0	0	N/A
Low	0	0	0	N/A

SLA Definitions: - Critical: 24 hours - High: 7 days - Medium: 30 days - Low: 90 days

---

Document Maintenance

VERSION	DATE	AUTHOR	CHANGES
1.0	[Date]	[Author]	Initial tracker

Last Updated: [Date] **Next Review**: [Date]

Engagement Sign-Off

By signing below, the client agrees that this unified scoping document satisfies the engagement coverage requirements for DORA, FRB, HKMA, and PRA compliance regimes.

Executive Sponsor:

Date: